

TRAINING @ FORREST ONE

Session 8 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Enterprise Network Security

Firewalls, IDS/IPS, VPNs and the secure protocols: defence at the network boundary.

ARCHITECTURE

FIREWALLS

IDS/IPS

VPN



WELCOME · WHERE WE ARE

The network foundation pays off

- **Sessions 1–3** addressing, switching and services
- **Sessions 4–7** security concepts, threats, cryptography and identity
- **Today** the controls that defend an enterprise network
- **The spine** physical space, segmentation, admission, keys and zones
- **The exam line** scenario questions: pick the control that fits the risk



SESSION OBJECTIVES

By the end of this session you will be able to

- **Secure the physical layer** rooms, closets, access control and surveillance
- **Plan deception** honeypots and honeynets, lawfully and isolated
- **Prove controls with audits** internal, external and the regulatory regimes
- **Segment the network** VLANs, zones and micro-segmentation by data sensitivity
- **Handle special environments** internet of things and industrial control systems
- **Onboard guests and personal devices** separate segments, captive portals and enrolment
- **Harden and admit** baselines, minimal functionality, NAC and 802.1X
- **Protect keys and content** the key lifecycle, filtering, inspection and trust zones



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

The physical layer starts at the door

- **Equipment rooms** hold servers and the core hardware
- **Wiring closets** hold cabling and switches, and are often overlooked
- **Data centres** need the strictest controls of all
- **Key and combination locks** cheap and keyless, but pickable or a shared code
- **Electronic access control** cards and fobs, and a lost card can be revoked instantly
- **Biometrics** hardest to share, and the costliest to run

Why it comes first

Physical access defeats every logical control above it, so secure the rooms first.



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

Controls around the room

Control	Job
Cameras	Cover every entry point, and minimise blind spots
Retention	Keep footage long enough to investigate an incident
Visitor management	Sign in, and escort visitors at all times
Access logs	Record who entered each secure space, and when
Security guards	A visible deterrent, plus a person who can respond

Policy decides retention

The retention period is set by policy and often by regulation. Footage you have already deleted proves nothing during an investigation.



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

Honeypots and honeynets

- **The honeypot** a decoy system built to attract an attacker away from real targets
- **Low interaction** few services simulated: simple, safe to run and shallow
- **High interaction** a full operating system: rich detail, and more risk
- **The honeynet** a whole network of decoys, which makes lateral movement visible
- **The value** you learn attacker tools and techniques, and get early warning
- **Isolation** mandatory: a decoy must never reach production systems

Contain the decoy

A decoy you cannot contain is a foothold you gave away. Internal decoys also catch insiders.



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

Deceiving lawfully: consent, privacy and entrapment

- **Consent** obtain consent to monitor, and tell staff what may be captured
- **Privacy** a decoy can capture personal data by accident, so configure it narrowly
- **Entrapment** a genuine legal risk, so never solicit or encourage an attack
- **The rule** a decoy waits, observes and records. It does not invite

Legal Lens

Get the paperwork right before you get clever. A decoy that breaks the law is worse than no decoy at all.



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

Internal and external audits

- **The question** an audit asks whether controls exist AND whether they work
- **Internal audit** run by your own team, who know the systems deeply
- **External assessment** an independent third party, often required by a regulator
- **Preparation** documentation, evidence, a staff briefing and a mock audit
- **Afterwards** remediate every finding, then follow up and verify the fix

Evidence

Evidence means logs, configurations and access records. A control nobody tests is only a hope.



TOPIC 8E · PHYSICAL, DECEPTION & AUDIT

The regimes you will meet

Regime	Demands
PCI DSS	Protect cardholder data; need to know access; monitor and test
GDPR	EU personal data: consent, access, correction and deletion
Data locality	Some countries require citizens' records to stay in country
Evidence	Logs, configurations and access records prove compliance

Where the data may live

Data locality decides which cloud regions you may use. Compliance you cannot evidence is compliance you cannot claim.



TOPIC 8A · ARCHITECTURE

Campus network architecture

- **Tiered model** core (fast transport), distribution (policy), access (endpoints)
- **Spine-leaf** data-centre fabric: every leaf to every spine, for low latency
- **SMB model** flat and single-layer: fewer devices, simpler policy
- **Redundancy** duplicate paths and devices, so nothing is a single point of failure
- **The choice** scale, budget, reliability and control drive the model



TOPIC 8F · SEGMENTATION & SPECIAL ENVIRONMENTS

Why we divide the network

- **The tool** a virtual local area network splits one physical switch into logical networks
- **Departments** HR, Finance and IT each get their own segment
- **Firewall zones** define what may cross between segments
- **Micro-segmentation** applies policy per workload, not per rack
- **Benefits** limit lateral movement, shrink the attack surface, meet compliance
- **The plan** start from data sensitivity and trust level, never from convenience

Containment

Segmentation is containment. Everything else is detection.



TOPIC 8F · SEGMENTATION & SPECIAL ENVIRONMENTS

Let data sensitivity set the trust level

- **Classify first** and let the classification drive the design
- **Highest controls** cardholder or health data, reached only by known devices and users
- **Looser zone** a public facing web server, because strangers must reach it
- **Still controlled** it gets monitoring and control, just not the same trust

Design Lens

Segmentation by data sensitivity and trust level is exactly what the card and health regimes expect to see.



TOPIC 8A · ARCHITECTURE

Segmentation in practice

- **VLANs** logical separation within a switch: different zones, different rules
- **DMZ** a buffer zone hosting public services, ringed by two firewalls
- **Micro-segmentation** fine-grained isolation, even within a single workload
- **Least connectivity** allow only the connections that are actually necessary
- **The benefit** a compromise in one segment does not spread everywhere



TOPIC 8F · SEGMENTATION & SPECIAL ENVIRONMENTS

Internet of things and industrial systems

- **IoT devices** low power, rarely patched, often shipped with default credentials
- **Industrial IoT** runs manufacturing, energy and logistics
- **Operational technology** controls physical processes: availability outranks confidentiality
- **SCADA and ICS** industrial control systems, legacy by design and by necessity
- **Give each family a segment** with strict rules and close monitoring
- **The rule** a compromised sensor must never reach the corporate network

Untrusted by default

These devices are untrusted whatever the vendor claims, because they cannot be patched like a laptop.



TOPIC 8F · SEGMENTATION & SPECIAL ENVIRONMENTS

The Purdue model for industrial networks

Level	Contents
Level 0 and 1	Field devices: sensors and actuators
Level 2	Process control: programmable logic controllers
Level 3	Site operations: manufacturing execution systems
Level 4	Enterprise systems: planning and business applications
Air gap	Physical isolation, used where intrusion risk must be near zero

Between every layer

Traffic between each level is controlled and monitored, even before you decide that an air gap is warranted.



TOPIC 8F · SEGMENTATION & SPECIAL ENVIRONMENTS

Availability first in operational technology

- **No patching window** you cannot patch an industrial controller during a production run
- **Reboot risk** a restart may be physically dangerous, so uptime outranks confidentiality
- **The shift** move from hardening the device to containing the segment
- **The controls** isolate behind firewalls, restrict what crosses, watch for anomalies

Security Lens

If you cannot fix the device, control its neighbourhood: filter the traffic and monitor it closely.



DISCUSSION

Why do internet of things sensors belong on their own segment, and what breaks if they share the office network?

Weak patching, default credentials and no authentication. Industrial devices add a harder constraint: availability outranks confidentiality. Compromised, they become pivot points into the whole network.

Segment by trust, not by convenience. These devices are untrusted by default.



TOPIC 8G · GUESTS AND BYOD

Designing a guest network

- **Separate segment** guests get their own VLAN, away from every internal resource
- **No internal access** firewall rules and access control lists block the path inward
- **Bandwidth cap** so guest traffic cannot crowd out business traffic
- **Captive portal** presents acceptable use terms before access is granted
- **The log** the portal also captures a name or address for the record

Guest means internet only

Internet only, with no route inward. Design the guest network as a dead end, not a shortcut.



TOPIC 8G · GUESTS AND BYOD

The captive portal earns its place

- **Redirection** the guest is sent to a web page before any internet access is granted
- **Terms** that page carries your acceptable use policy, and agreement is recorded
- **Identity** it captures a name or an address for the access log
- **Change control** it gives you one place to publish changed terms later

Practice Lens

The portal is a control point, not just a splash screen. It records who accepted what, and when.



TOPIC 8G · GUESTS AND BYOD

Bring your own device

- **The appeal** personal devices are convenient, and far harder to control
- **The problem** you do not own the hardware, or know what else runs on it
- **Segment them** and limit what personal devices can reach
- **Enrol them** in mobile device management, so policy can be enforced
- **Certificates** certificate based authentication proves the device is one you know
- **The trade** user convenience against a larger attack surface

Manage the trade

Manage the trade deliberately, not by accident. A device you cannot revoke is a device you cannot control.



TOPIC 8G · GUESTS AND BYOD

Making personal devices safe enough

- **Define compliance** write down what a compliant personal device looks like
- **Enrol or deny** if the device does not enrol, it does not connect
- **Issue a certificate** so the network recognises the device, and can revoke it
- **Separate data** keep work data apart from personal data where the platform allows
- **Prepare to wipe** be ready to remove corporate data from a lost device
- **Publish the policy** users accept the rules before they enrol

Rules people can follow

Convenience is fine. Unmanaged convenience is not. People accept rules they can read.



BREAK
10 MINUTES

Back soon: hardening the devices you own, then admission control.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Reducing the attack surface

- **Hardening** remove everything the device does not need
- **Credentials first** change default usernames and passwords immediately, everywhere
- **Close the doors** disable unused services, close unused ports, drop unused protocols
- **Patch promptly** apply firmware updates and security patches, and automate it
- **Baseline** build a secure configuration baseline, then audit against it
- **The principle** minimal functionality: only the job you bought it for

Somewhere to knock

Every service, port and protocol you leave running is somewhere an attacker can knock.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Baselines, compliance and minimal functionality

- **The baseline** one documented standard for each type of device
- **Compliance verification** audit every device against that baseline
- **Automation** automated tools catch configuration drift before an auditor does
- **Minimal functionality** a router routes, it does not host a website
- **Why it matters** fewer features means less to patch, manage and explain

Drift is the enemy

Devices change: someone alters a setting and nobody records it. Audit to catch the difference.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Use a published guide, not your memory

- **CIS benchmarks** the Centre for Internet Security publishes them for common systems
- **NIST publications** the National Institute of Standards and Technology frameworks
- **Vendor guides** most vendors publish a hardening guide for their own products
- **Then verify** run automated checks and regular audits against your baseline

Exam Trap

Do not invent a baseline from memory. A baseline nobody checks is only a document.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Network access control: posture assessment

- **The gatekeeper** network access control checks a device before it joins
- **Antivirus** presence and currency, checked at the door
- **Patches, settings and user** operating system updates, configuration, credentials
- **Outcomes** deny outright, or quarantine into a restricted segment
- **Remediation network** lets a failing device reach patch servers, then try again

Two checking styles

Agent based checking gives rich detail; agentless installs nothing, so it is shallower.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Port based authentication: 802.1X

- **802.1X** authenticates a device at the switch port, before traffic flows
- **Three roles** the device is the supplicant, the switch is the authenticator
- **The decision** the switch relays credentials, and a central server judges them
- **RADIUS** remote authentication dial in user service: authentication and accounting
- **Scale** it handles thousands of devices, and can use certificates
- **Failure** an unauthenticated port can be shut, or dropped into a guest segment

The whole idea

No authentication, no traffic. The switch port stays closed until the device proves who it is.



TOPIC 8B · HARDENING & ADMISSION CONTROL

Roll network access control out in phases

- **The risk** it is easy to lock out your own staff by accident
- **Monitor mode** run it first to see what it would have blocked
- **Pilot** start with a small, controlled group, then refine the policies
- **Expand** segment by segment, watching for false positives as you go

Practice Lens

Test before you enforce, and you keep both security and goodwill. False positives are the main complaint.



TOPIC 8H · KEY MANAGEMENT & CONTENT CONTROL

The life of a key

- **Generation** secure random values, seeded from real entropy such as hardware noise
- **Distribution** getting the key to the right party without exposing it
- **The hard part** symmetric keys, because both sides must hold the same value
- **Storage** hardware security modules, key vaults and secure enclaves
- **Rotation** change keys on a schedule, to limit the damage of a leak
- **Revocation and destruction** invalidate the key, then erase it everywhere

Cryptography is only as strong as the keys

Poor key management defeats perfect cryptography. Every stage of the key lifecycle can fail.



TOPIC 8H · KEY MANAGEMENT & CONTENT CONTROL

Where keys live

Store	What it gives you
Hardware security module	A physical device that performs crypto without exposing the key
Key vault	Software storage with access control, auditing and logging
Secure enclave	Isolated execution inside the processor
Key management system	Central control of the whole key lifecycle

Out of casual reach

Store keys where they cannot be casually read by the host, an administrator or a backup job.



Rotation limits the blast radius

- **Why rotate** a key that never changes is a key an attacker keeps forever
- **The schedule** rotating limits how much any single compromise can expose
- **The overlap** keep the retired key only as long as you must read old data
- **Then finish it** revoke it, then destroy it everywhere, including backups

Analyst's Lens

Rotation limits the blast radius. Destruction is the last stage of the lifecycle, not an afterthought.



Access control lists and URL filtering

- **Access control list** allows or denies by source, destination, port or protocol
- **Order matters** rules are evaluated in sequence, and the first match wins
- **The classic error** a permit everything rule at the top makes the rest decoration
- **URL filtering** blocks whole categories: social media, gaming, malicious
- **DNS filtering** blocks the name lookup, before any connection exists

Plan the rule set

Plan the rule set, or you will break something legitimate. Review it regularly.



TOPIC 8H · KEY MANAGEMENT & CONTENT CONTROL

Inspecting what flows

Control	Job
Content filtering	Scan traffic for malicious content, and block it
Deep packet inspection	Examine packet contents in real time
Data loss prevention	Stop sensitive data leaving the organisation
Web proxy	Enforce policy, cache content, and hide internal addresses

Two different questions

Filtering decides what is allowed; inspection decides what is safe. You need both answers.



TOPIC 8A · TRUST ZONES & ARCHITECTURE

Trust zones and the screened subnet

- **Untrusted zone** the internet, which anyone can reach and nobody controls
- **Trusted zone** internal networks, data centres and private cloud
- **Semi-trusted** partner networks, branch offices and guest networks
- **Screened subnet** also called a demilitarised zone, or DMZ, for public services
- **It is a buffer** reachable from outside, and deliberately separated from inside
- **Zone policy** zone based firewall policies govern every path between zones

A design decision

Trust is a design decision, not a location. A zone is a boundary you can write a rule against.



TOPIC 8A · TRUST ZONES & ARCHITECTURE

Zone policy, defence in depth and zero trust

Principle	What it means
Zone based policy	Rules decide what may cross between zones
Deliberate asymmetry	Internal users reach the DMZ; the DMZ cannot reach back in
Defence in depth	Several layers of control, because no single one is foolproof
Zero trust	No implicit trust from location; verify identity and context

The habit to keep

A compromised public server must not become a doorway. Verify identity and context on every request, then prove the control works.



TOPIC 8B · SECURITY APPLIANCES

Exam reference: the appliance stack

Control	Job
Firewall, stateless	Filters each packet by address, port and protocol, with no context
Firewall, stateful	Tracks connections in a state table, and allows established flows
NGFW and UTM	Application awareness, deep packet inspection and threat intelligence
IDS and IPS	Detection alerts and logs; prevention sits inline and blocks
Signature or anomaly	Signatures catch known attacks; anomaly detection flags deviations

Exam line

IDS detects and alerts; IPS sits inline and blocks. A load balancer that fails is a single point of failure.



QUIZ

Activity: place the appliance

- Which appliance inspects application-layer web attacks?
- Which appliance blocks malicious traffic inline?
- Which appliance should NOT be a single point of failure?
- Which appliance hides the internal topology?
- Debrief: what happens when each fails?

WAF for web apps · IPS blocks inline · load balancers need redundancy · proxies mask topology.



TOPIC 8C · SECURE REMOTE ACCESS

Exam reference: remote access

Option	What it is
Site-to-site VPN	Connects whole networks, branch to headquarters, often IPsec tunnel mode
Remote access VPN	Connects one device: client-based, or an SSL VPN in the browser
Split tunnel	Only some traffic crosses the tunnel, and the rest goes direct
ZTNA and SASE	Verify identity and posture per request; SASE delivers it as a service

Every remote path needs all three

Authentication, encryption and monitoring. RDP is a favourite target: MFA, firewall allowlists, patching, monitoring, and jump servers or bastion hosts for administrators.



QUIZ

Activity: lock down remote access

- RDP must stay enabled for one admin. List the controls you add.
- Branch users need the HQ systems. Which VPN type?
- A contractor needs browser-only access. Which option?
- Debrief: which control is non-negotiable?

MFA, firewall allowlists, patching, monitoring, and MFA again. Site-to-site for branches; SSL VPN for browser-only.



TOPIC 8D · SECURE PROTOCOLS

Exam reference: the secure protocol toolkit

Protocol	Job
TLS / HTTPS	Transport encryption for web and APIs (TLS 1.2 and 1.3)
SSH / SFTP	Secure remote administration and file transfer
IPsec	Network-layer encryption for VPNs, in tunnel mode
S/MIME	Email signing and encryption
DNSSEC / HSTS	DNS response integrity; browsers refuse plaintext HTTP

Exam line

Perfect forward secrecy uses ephemeral keys, so past traffic stays secret if a key leaks. Certificate validation checks the chain, hostname, expiry and revocation, which is what defeats a man in the middle.



KEY TAKEAWAYS

- **Secure the rooms first** physical access defeats every logical control.
- **Isolate your decoys** and keep the monitoring lawful.
- **Audit to prove it works** evidence is logs and configurations.
- **Segment by data sensitivity** then contain industrial systems.
- **Trust guests and BYOD with a segment** never with internal access.
- **Rotate keys and filter content** and verify identity per request.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Draw a zone diagram** untrusted, screened subnet, internal and management, for a network you know
- **Match the controls to the risk** physical, segmentation, NAC, keys, filtering, zones
- **Read ahead** Session 9: endpoint, application, cloud and virtualisation security



QUIZ

Check your understanding

- Open Quiz_Session_08.html in your browser.
- 20 questions, immediate feedback, topic tag on every question.
- Read each explanation: the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a session topic, e.g. 8C Secure Remote Access.



NEXT SESSION

Session 9 — Endpoint, Application, Cloud & Virtualisation Security

- Endpoint hardening, EDR and mobile device management
- Secure development lifecycle and application-layer attacks
- Cloud service models, shared responsibility and the hypervisor

